Security Assessment Report

Prepared by FusionHawk for Anarock Property Consultants Pvt. Ltd. | Date: 2026-10-16 | Repository fusionhawk/Anarock, main @ fcdc286 | Standards: OWASP Top 10 2021, OWASP API Security Top 10 2023, OWASP ASVS 4.0 Level 2 | Severity from CVSS v3.1 base score

1. Executive summary

Overall risk: High. 18 items: 1 critical, 3 high, 9 medium, 4 low, 1 informational. The most important issues: (1) Next.js 14.2.35 with a critical advisory and a lockfile that cannot be installed with npm ci; (2) the public property API returns every Data Store column, which in production includes SPOC contact numbers (152 rows) and achievable rent (151 rows); (3) /api/lead2 is unauthenticated, unvalidated and writes client-chosen values into production CRM; (4) duplicate-lead handling lets the public overwrite existing CRM leads; (5) the rate limiter is bypassed by spoofing X-Forwarded-For; (6) no security headers. New this run: Catalyst platform configuration review (public sign-up enabled, default App User role can write to tables, unencrypted bucket) and the first OWASP ZAP passive scan, which independently confirms the missing headers.

Every finding below states how it was verified (executed test, scan, connector query or code read). Items that need Catalyst or Zoho credentials, a CRM sandbox or production writes were not exercised and are marked as such.

2. Activities performed this run (raw logs in reports/evidence/)

#	Activity	Result	Evidence
1	Clean sandbox and fresh clone of fusionhawk/Anarock main	Done; HEAD fcdc286 (app code unchanged since b504988, 2026-10-08)	00_clean.log, 01_git_clone.log
2	Scope document read from the repository and compared with code	Done (see Scope Completeness report)	11_scope_doc_comparison.log
3	Zoho CRM inspected read-only via the AnarockCRM connector	Org, modules, Leads and Properties field metadata, record counts, COQL reads. No writes.	10_crm_inspection.log
4	Catalyst inspected read-only via the anarock CLA Catalyst connector	Functions, Data Store tables/columns/counts, Stratus, Slate, API Gateway, CORS, auth, env-variable names (none set). No writes.	10b_catalyst_inspection.log
5	npm ci / npm audit	npm ci FAILS (lock out of sync); npm audit 13 vulnerabilities (1 critical, 10 high, 2 moderate)	02_npm_ci_audit.log
6	Semgrep 1.181.0 (p/javascript, p/nextjs, p/owasp-top-ten, p/secrets)	Project: 0 findings, 0 errors, 105 files. Scanner proven on known-bad sample: 3 findings	06_sast_semgrep.log
7	Secret scan of working tree and full git history	149 text files and 711,474 added lines in 54 commits: 0 real hits (4 false positives); regex scanner proven on a known-bad sample	05_secret_scan.log
8	GitHub secret scanning	NOT possible: 'Repository does not have GitHub Advanced Security enabled'	07_github_secret_scanning.log
9	OWASP ZAP 2.16.1 spider + passive scan vs local app	Installed and run (java 21). 4 medium/low alert types, 4 informational. Active scan deliberately not run	06b_zap_attempt.log, 06c_zap_baseline.log
10	Scripted request tests (headers, validation, rate-limit bypass, error leakage, CORS, body size)	84 checks: 49 pass / 35 fail	08_api_tests.log, run_api_tests.sh
11	Browser tests (Playwright 1.56.1 + axe-core 4.10.2) at 1366px and 375px	103 checks: 86 pass / 17 fail	09_browser_tests.log, run_browser_tests.js
12	Manual review of active API and lib code	About 28,265 lines of application code (excluding generated UI components) read; commented-out code excluded from findings	build_reports.py findings table

The app ran locally with no Zoho or Catalyst credentials, so no request could reach production CRM or Data Store. All CRM and Catalyst access was through read-only connector calls.

3. Findings

Severity bands (CVSS v3.1): Critical 9.0-10, High 7.0-8.9, Medium 4.0-6.9, Low 0.1-3.9. IDs are kept stable across runs. Severity is now assigned strictly from the CVSS base score; S-03 (6.5) and S-14 (4.2) are therefore Medium where earlier runs said High and Medium by judgement.

ID	Severity	Finding	Category (OWASP 2021 / API 2023 / ASVS L2)	CWE	CVSS 3.1	How verified	Recommendation
S-01	Critical	Next.js 14.2.35 (and the eslint-config-next / tailwindcss chains) carry known advisories: npm audit = 13 (1 critical, 10 high, 2 moderate). Advisories include image-optimizer DoS/RCE, request smuggling in rewrites, cache confusion and server-function disclosure. package-lock.json is out of sync with package.json, so npm ci fails and builds are not reproducible.	A06:2021 Vulnerable and Outdated Components **API:** API8:2023 Security Misconfiguration **ASVS:** V14.2.1	CWE-1104, CWE-937	**9.8** AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	Executed: npm audit (02_npm_ci_audit.log); npm ci (fails: lock missing @emnapi/core, @emnapi/runtime 1.11.3). Score reflects the worst advisory; exploitability in this deployment (which advisory features are used) was not tested.	Upgrade Next.js to a patched release, regenerate and commit the lockfile, run npm audit in CI.
S-04	High	Duplicate-lead handling lets an anonymous caller overwrite fields of an existing CRM lead (PUT /crm/v8/Leads/{id} with attacker-supplied values, workflows triggered), and the response reveals whether the phone/email already exists plus the CRM lead ID and owner team. Same pattern in lead3.	A01:2021 Broken Access Control **API:** API1:2023 BOLA; API3:2023 BOPLA **ASVS:** V4.2.1, V8.3.4	CWE-639, CWE-285, CWE-200	**8.2** AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:N	Code read: leads/route.js duplicate handling (about lines 498-540 and the PUT path) and response fields. Not executed end-to-end: needs a CRM sandbox (no production writes were made).	Never update an existing lead from public input: create a note/task instead; return a generic response without IDs.
S-02	High	/api/lead2 (home-page 'post a requirement' form) has no rate limit, no content-type or body-size check, no honeypot and no phone/email format validation, and writes client-supplied leadSource, leadStatus and subLeadSource straight into CRM Lead_Source, Lead_Status and Sublead_Source (CRM picklists include 'Listing Platform', 'Qualified', 'Junk Lead'). Lead creation triggers CRM workflows.	A04:2021 Insecure Design; A03:2021 Injection (unvalidated input) **API:** API6:2023 Unrestricted Access to Sensitive Business Flows; API3:2023 BOPLA **ASVS:** V5.1.3, V11.1.4, V13.2.1	CWE-20, CWE-915, CWE-770	**7.5** AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N	Runtime: invalid phone/email, text/plain and 60KB bodies all reached the CRM-token step (HTTP 500, not 400/415/413); 15 consecutive POSTs never returned 429 (08_api_tests.log). Code: lead2/route.js (field pass-through). CRM picklists read live (10_crm_inspection.log).	Reuse the validation of /api/leads; whitelist source/status server-side; add CAPTCHA and gateway throttling.
S-07	High	The public property API returns the entire Data Store row: propertyMapper spreads ...row into the response with no field whitelist. The production Properties table has columns SPOCName, SPOCNumber (non-empty in 152 of 395 rows), AchievableRent (non-empty in 151), QuotedRent, crmID and CREATORID, so internal contact numbers and internal pricing are served to anonymous users. When no page params are sent the whole catalogue is returned in one response.	A01:2021 Broken Access Control; A04:2021 Insecure Design **API:** API3:2023 Broken Object Property Level Authorization **ASVS:** V8.3.4, V13.2.2	CWE-213, CWE-359, CWE-200	**7.5** AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N	Code: propertyMapper.js:23-27 (...row) and properties/[id]/route.js returns the mapped row; no SPOC* stripping anywhere (grep). Catalyst Data Store read via connector: column list and COUNT queries (10b_catalyst_inspection.log). Runtime response NOT demonstrated: needs Catalyst credentials.	Whitelist public fields in a DTO; drop SPOC*, AchievableRent, crmID, CREATORID; cap pageSize.
S-03	Medium	Rate limiting on /api/leads and /api/lead3 keys on the client-supplied X-Forwarded-For header and stores counters in a per-instance in-memory Map that is never purged. Rotating the header bypasses the 10 req/min limit entirely, and the Map grows without bound.	A04:2021 Insecure Design **API:** API4:2023 Unrestricted Resource Consumption **ASVS:** V11.1.4, V13.4.1	CWE-348, CWE-770	**6.5** AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:L	Runtime: same client blocked on request 11 (429); 12 requests with a different X-Forwarded-For each returned 400, never 429 (both endpoints). Code: leads/route.js:121-160.	Use the platform-trusted client IP, a shared store, and API Gateway throttling (required by SoW 3.2).
S-10	Medium	Long-lived Zoho OAuth refresh tokens (CRM and Catalyst) are held in app environment and used for every server call; scope and rotation are not documented. The code defaults to the Catalyst 'Production' environment and a hard-coded Properties table ID when env vars are absent, while .catalystrc contains only a Development environment. The Production Slate app has no environment variables configured.	A05:2021 Security Misconfiguration; A07:2021 Identification and Authentication Failures **API:** API2:2023 Broken Authentication; API8:2023 **ASVS:** V2.10.1, V6.4.1, V14.1.3	CWE-1188, CWE-522	**5.9** AV:N/AC:H/PR:H/UI:N/S:U/C:H/I:H/A:N	Code: catalyst.js:331-332 and :412 (defaults), zoho.js; .catalystrc; Slate env-variable list for the Production deployment is empty (connector).	Least-privilege scopes, separate dev/prod credentials, fail closed when env is missing, document rotation.

ID	Severity	Finding	Category (OWASP 2021 / API 2023 / ASVS L2)	CWE	CVSS 3.1	How verified	Recommendation
S-17	Medium	Catalyst platform configuration (read-only via connector): project authentication has public sign-up enabled (hosted auth) although the site has no end-user accounts; the default role 'App User' holds SELECT/UPDATE/INSERT on the Properties table; the Stratus bucket property-images has encryption and audit logging off; CORS list in Production contains 127.0.0.1 and crm.zoho.in; the only API Gateway rule (stratus_upload, method ANY) points at a function that is not deployed. Potential for anonymous sign-ups to obtain table write permission through Catalyst client APIs was NOT tested (no writes allowed).	A05:2021 Security Misconfiguration; A01:2021 Broken Access Control **API:** API8:2023 Security Misconfiguration **ASVS:** V14.1.1, V4.1.3	CWE-1188, CWE-276, CWE-732	**5.4** AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N	Connector reads: Get_Authentication_Configurations, Get_Table_Permissions, Get_All_Buckets, List_All_CORS_Domains, List_All_API_route (10b_catalyst_inspection.log). Exploitation not tested.	Disable public sign-up; give App User SELECT only; enable bucket encryption; remove localhost CORS from Production; review the gateway rule.
S-05	Medium	Public API responses expose internal error text, including environment-variable names (CATALYST_PROJECT_ID is missing, ZOHO_CLIENT_ID is missing), and the same text is rendered to users on /properties, /kyc and property pages. Fallback JSON.stringify(error) can serialise arbitrary SDK errors.	A05:2021 Security Misconfiguration **API:** API8:2023 Security Misconfiguration **ASVS:** V7.4.1	CWE-209	**5.3** AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	Runtime (no credentials): GET /api/properties, /api/properties/1, /api/kyc, /api/cities, /api/micromarkets return env-var names; browser tests show the text on 3 pages (08, 09 logs). Code: properties/[id]/route.js catch block.	Return generic messages; log details server-side only.
S-08	Medium	The public layer does not enforce 'Published/approved'. Every Data Store row is served (propertiesCache maps all rows, no status filter). Production Data Store holds 395 Properties rows while CRM has 393 with Push_to_Website=true, and the Data Store table has no publish/status column. The sync that should enforce validation is not in the repository and no Catalyst function or cron is deployed.	A04:2021 Insecure Design **API:** API6:2023 Unrestricted Access to Sensitive Business Flows **ASVS:** V1.4.1, V11.1.1	CWE-841	**5.3** AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	Code: propertiesCache.js:118; Data Store columns and COUNT (395) vs CRM COUNT (393) via connectors (10, 10b logs).	Add an explicit published flag in the Data Store, check it in the app and in the sync function.
S-15	Medium	Public lead endpoints can be driven from any website: /api/lead2 accepts a cross-origin text/plain POST (no CORS preflight needed), so any third-party page can make visitors' browsers submit leads. The 50KB body limit in /api/leads and /api/lead3 relies on Content-Length and is skipped by chunked requests.	A01:2021 Broken Access Control; A04:2021 Insecure Design **API:** API4:2023 Unrestricted Resource Consumption **ASVS:** V13.2.3, V4.2.2	CWE-352, CWE-770	**4.3** AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N	Runtime: cross-origin text/plain POST to /api/lead2 processed (500 at CRM stage, not 415); 60KB chunked POST to /api/leads parsed and rejected 400 instead of 413 (08_api_tests.log).	Enforce Origin checks, JSON-only content type and a streaming body-size limit.
S-09	Medium	Property detail page title and metadata are built from the URL slug, so any text can be injected into a page title that is served HTTP 200 and is indexable (content spoofing / SEO poisoning); unknown IDs are not 404. ZAP also flagged a user-controllable HTML attribute (requirementArea) on the home form.	A04:2021 Insecure Design **API:** n/a **ASVS:** V5.1.1, V5.3.3	CWE-20, CWE-451	**4.3** AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N	Runtime: /properties/abc/xyz -> HTTP 200 (08_api_tests.log); HTML in slug is escaped in <title> (XSS test passes). Code: properties/[id]/[name]/page.js generateMetadata.	Fetch the property server-side, derive the title from data, return notFound() when missing, redirect to the canonical slug.
S-06	Medium	No security headers: no CSP, HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy or Permissions-Policy; X-Powered-By is exposed; no Origin/CSRF check on POST routes. OWASP ZAP passive scan independently reports CSP not set (32 URLs), missing anti-clickjacking (16), X-Powered-By leak (32) and X-Content-Type-Options missing (123).	A05:2021 Security Misconfiguration **API:** API8:2023 Security Misconfiguration **ASVS:** V14.4.1-V14.4.7, V14.5.3	CWE-693, CWE-1021, CWE-497	**4.2** AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N	Executed: curl -I on / (7 header checks fail) and ZAP 2.16.1 passive scan (06c_zap_baseline.log). next.config.mjs has no headers(). Scan was against the dev server; TLS/HSTS cannot be judged on http://localhost.	Add headers() in next.config, set poweredByHeader:false, add Origin checks on POST.
S-14	Medium	Repository hygiene: GitHub Advanced Security (secret scanning / push protection) is not enabled on fusionhawk/Anarock; .gitignore files only ignore '.env*.local' (root) and '.env.local' (anarock/), so a plain .env or .env.production would be committed; git history contains 4,118 node_modules files and 787 .build/ function-bundle files from earlier commits (repository bloat, and secrets could hide in that volume). No secrets were found today.	A05:2021 Security Misconfiguration; A08:2021 Software and Data Integrity Failures **API:** API8:2023 **ASVS:** V10.3.2, V14.1.2	CWE-540, CWE-1188	**4.2** AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:N	Executed: GitHub run_secret_scanning call returned 'Repository does not have GitHub Advanced Security enabled' (07); history scan of 54 commits / 711,474 added lines: 0 real hits (4 false positives, header-name constants) (05); git log --diff-filter=A listing of node_modules and .build.	Enable secret scanning and push protection; ignore .env and .env.*; add a pre-commit scanner; purge build artefacts from history if the repository is to be shared.

ID	Severity	Finding	Category (OWASP 2021 / API 2023 / ASVS L2)	CWE	CVSS 3.1	How verified	Recommendation
S-11	Low	/api/location: the Nominatim 1 req/s throttle is not serialised (concurrent requests read the same timestamp), the in-memory cache is unbounded, precise user coordinates are sent to a third party without a consent notice, malformed JSON returns 500, and failures return HTTP 200.	A04:2021 Insecure Design **API:** API4:2023 Unrestricted Resource Consumption **ASVS:** V8.3.1, V11.1.4	CWE-362, CWE-400, CWE-359	**3.7** AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:L	Runtime: malformed JSON body -> 500 (08_api_tests.log). Code: location/route.js:20-30.	Serialise with a lock, bound the cache, add a consent notice (DPDP), return 4xx for bad input.
S-12	Low	Catalyst Web SDK 4.6.2 is loaded from static.zohocdn.com on every page without Subresource Integrity, and no use of the SDK was found in client code.	A08:2021 Software and Data Integrity Failures **API:** API8:2023 **ASVS:** V14.2.3	CWE-829, CWE-353	**3.7** AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N	Code: layout.js:79; grep for Catalyst client usage found none outside server libs.	Remove if unused, otherwise add SRI and restrict via CSP.
S-18	Low	The lead forms have no method/action fallback: when ZAP's spider submitted the home form without JavaScript the browser used GET and put email, company and requirement text into the URL query string (ZAP 'Sensitive Information in URL'), which is logged by proxies and kept in history/referrers.	A04:2021 Insecure Design **API:** n/a **ASVS:** V8.3.1	CWE-598	**3.1** AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N	Executed: ZAP passive alert 10024 (06c_zap_baseline.log) with evidence of an email address in the URL; form markup in HomePage.js:2025 / HeroSection.js:1610.	Add method="post" and a safe action, or prevent native submit.
S-13	Low	Raw user search 'prompt' text is written to server logs; verbose console.log/console.error output (193 statements in 27 files) including full error objects and stacks.	A09:2021 Security Logging and Monitoring Failures **API:** API8:2023 **ASVS:** V7.1.1, V7.1.2	CWE-532	**2.3** AV:L/AC:L/PR:H/UI:N/S:U/C:L/I:N/A:N	Code: properties/route.js:587-592; grep console.* counts (193 / 27 files).	Remove or redact; use structured logging with levels.
S-16	Info	Positive controls verified: honeypot returns a fake success to bots; /api/leads and /api/lead3 enforce 415 on wrong content-type, length limits, phone and email validation and 429 after 10 requests/min per (header-derived) client; no secrets in the working tree or in 54 commits of history (.catalystrc holds IDs only); breadcrumb JSON-LD is escaped; wishlist is client-side only; target=_blank links carry rel=noopener; cookies are not set before consent; Semgrep reports 0 findings.	n/a **API:** n/a **ASVS:** V5.1.3, V8.3.1	-	-	Runtime tests, secret scan (05), Semgrep (06), browser tests (09).	Keep and reuse across all endpoints.

4. Controls tested and not tested

Control / area	Status	Detail
Dependency vulnerabilities (A06)	Tested - FAIL	npm audit 13; lockfile unusable with npm ci
SAST (Semgrep OWASP packs)	Tested - pass	0 findings in 105 files; canary proves rules fire. Pattern tools do not find logic flaws such as S-02/S-04
Secrets in tree and history	Tested - pass	0 real hits; 4 header-name false positives; GitHub secret scanning unavailable (S-14)
Security headers (CSP, HSTS, XFO, XCTO, Referrer, Permissions)	Tested - FAIL	All six absent; X-Powered-By present (curl + ZAP). HSTS only meaningful over TLS: not verifiable on http://localhost
Input validation on lead endpoints	Tested - mixed	/api/leads and /api/lead3 validate; /api/lead2 does not; malformed JSON gives 500 on /api/leads
Rate limiting and bypass	Tested - FAIL	Limit exists on 2 of 3 lead endpoints and is bypassable via X-Forwarded-For
Body-size limits	Tested - FAIL	Content-Length enforced (413); chunked bodies not (400); lead2 has none
CORS	Tested - pass	No wildcard or reflected Access-Control-Allow-Origin on /api/properties or OPTIONS /api/leads (but see S-15: simple POSTs need no preflight)
Error leakage	Tested - FAIL	Env-var names exposed by 5 API routes and rendered on 3 pages
XSS (reflected, title, JSON-LD)	Tested - pass	HTML in slug escaped; JSON-LD escaped; ZAP reports one user-controllable attribute (informational)
Passive DAST (OWASP ZAP)	Tested	Spider found 251 URLs; alerts in 06c_zap_baseline.log
Active DAST / fuzzing	NOT run	Excluded by design: active scanning of the lead endpoints would generate junk requests against code that reaches the CRM-token step; no isolated CRM sandbox exists
Authentication / session management	N/A	Site has no end-user login; wishlist session ID is client-side. Catalyst sign-up is open (S-17)
Authorization of CRM/Data Store access	Partly tested	Connector view of roles and table permissions (S-17); runtime exploitation not tested
Duplicate-lead overwrite, lead creation end-to-end	NOT tested	Needs CRM sandbox; production writes forbidden
Data Store/Stratus responses, image ACLs	NOT tested	No Catalyst credentials for the app; bucket public/protected type not returned by the API
TLS configuration, HSTS preload, certificates	NOT tested	Local http only; no Production Slate deployment exists (failed)
Load / DoS testing	NOT done	Out of agreed method; in-memory limits noted as design risk
Infrastructure / WAF / monitoring	No evidence	No logging, alerting or monitoring configuration exists in repo or Catalyst (no cron, no job pools)
Third-party penetration test	NOT done	This is an automated weekly assessment, not a pen test

5. Standards coverage

OWASP Top 10 2021	Result	Findings
A01 Broken Access Control	Fail	S-04, S-07, S-15, S-17
A02 Cryptographic Failures	Not assessed in depth	Stratus bucket unencrypted (S-17); TLS not verifiable
A03 Injection	No injection-class issue found	Semgrep 0; unvalidated lead2 input (S-02)
A04 Insecure Design	Fail	S-02, S-03, S-08, S-09, S-11, S-18
A05 Security Misconfiguration	Fail	S-05, S-06, S-10, S-14, S-17
A06 Vulnerable and Outdated Components	Fail	S-01
A07 Identification and Authentication Failures	Partly	S-10 (tokens); no user auth to test
A08 Software and Data Integrity Failures	Fail	S-12, S-14
A09 Logging and Monitoring Failures	Fail	S-13; no monitoring exists
A10 Server-Side Request Forgery	Not found	Server fetches only fixed hosts (Zoho, Nominatim, Frankfurter); code read

OWASP API Top 10 2023	Result	Findings
API1 BOLA	Fail (code)	S-04
API2 Broken Authentication	n/a (no user API); token handling	S-10
API3 Broken Object Property Level Authorization	Fail	S-02, S-04, S-07
API4 Unrestricted Resource Consumption	Fail	S-03, S-11, S-15
API5 Broken Function Level Authorization	Not found	No admin functions exposed; Catalyst roles in S-17
API6 Unrestricted Access to Sensitive Business Flows	Fail	S-02, S-08
API7 SSRF	Not found	see A10
API8 Security Misconfiguration	Fail	S-01, S-05, S-06, S-17
API9 Improper Inventory Management	Fail	Two Development Slate apps and one failed Production app serve the same code; stray /HomePage route; undeployed stratus_upload with a live gateway rule
API10 Unsafe Consumption of APIs	Partly	Frankfurter/Nominatim responses used without schema validation (code read)

ASVS 4.0 chapter (L2)	Result	Basis
V1 Architecture	Partial	No threat model; no published-only enforcement (S-08)
V2 Authentication	N/A	No end-user authentication
V3 Session management	N/A	No server sessions
V4 Access control	Fail	S-04, S-07, S-17
V5 Validation, sanitisation, encoding	Partial	S-02, S-09; output encoding sound
V6 Stored cryptography	Not verifiable	Stratus encryption off; Data Store encryption not queryable
V7 Error handling and logging	Fail	S-05, S-13
V8 Data protection	Fail	S-07, S-18
V9 Communications	Not verifiable	No TLS endpoint available (Production deployment failed)
V10 Malicious code	Pass	Semgrep and review found none; S-12 note
V11 Business logic	Fail	S-02, S-03, S-08
V12 Files and resources	N/A	No upload in the app (stratus_upload function not deployed)
V13 API and web service	Fail	S-02, S-15
V14 Configuration	Fail	S-01, S-06, S-10, S-14, S-17

6. Dependency audit (npm audit, executed this run)

Package	Severity	Affected range	Note
next (installed 14.2.35, direct)	critical	9.3.4-canary.0 - 16.3.0-preview.10	Fix needs a major upgrade (npm suggests 16.4.2)
eslint-config-next (direct)	high	14.0.5-canary.0 - 15.0.0-rc.1	Dev-time
tailwindcss (direct, via chokidar/fast-glob/micromatch)	high	0.5.0 - 3.4.19	Dev-time
postcss, source-map-js, postcss-selector-parser and other transitive packages	high / moderate	various	Total 13: 1 critical, 10 high, 2 moderate

7. OWASP ZAP passive scan results (spider + passive, local dev server)

Alert	Risk	CWE	Instances
Content Security Policy (CSP) Header Not Set	Medium	693	32
Missing Anti-clickjacking Header	Medium	1021	16
Server leaks information via X-Powered-By	Low	497	32
X-Content-Type-Options header missing	Low	693	123
Content-Type header missing (API root)	Info	345	1
Sensitive information in URL (form submitted by GET)	Info	598	1
Suspicious comments (dev bundle)	Info	615	73
User-controllable HTML element attribute	Info	20	1

ZAP also logged an XML parse error on sitemap.xml (unescaped '&' in /services&tools;); that is a code-review item. Findings from a development server (next dev) can differ from a production build; header findings apply to both because next.config has no headers().

8. Limitations and technical blocks

- No Zoho or Catalyst credentials and no CRM sandbox were available to the app: Data Store, Stratus and CRM-write flows (listing results, detail data, lead creation end to end, duplicate-lead behaviour, KYC and market-stats data) could not be executed and are marked Blocked or Not verifiable. Findings S-04, S-07 and S-08 rest on code plus read-only connector evidence, not on a captured production response.

- Connectors used: AnarockCRM and anarock CLA Catalyst, both enabled and working this run (read-only calls only). Catalyst function source code and Stratus object listings are not retrievable through the connector; build logs for the failed Production Slate deployment returned no data.

- GitHub secret scanning needs GitHub Advanced Security, which is not enabled (S-14). ZAP active scan, load testing and TLS testing were not performed (see section 4).

- SAST found no injection-class issues, but the main findings are logic and design flaws that pattern-based tools do not detect. No application code was modified; the only repository changes are README.md and reports/.

9. Priority remediation

1) Upgrade Next.js, fix the lockfile, add npm audit to CI. 2) Whitelist public property fields (S-07) and enforce a published flag (S-08). 3) Lock down /api/lead2 and the duplicate-update path (S-02, S-04); move throttling to a trusted layer with CAPTCHA (S-03, S-15). 4) Stop leaking errors and add security headers (S-05, S-06). 5) Tighten Catalyst configuration: disable public sign-up, reduce App User permissions, encrypt the bucket (S-17). 6) Review OAuth scopes and environment defaults (S-10); enable GitHub secret scanning (S-14).